

CyberThreat Intelligence Intro

Yihao Lim

Group Presentation

1. Be sure to cover

- Who
- What
- Where
- When
- Why
- How

Presentation will be 15 mins , Q&A 5 mins

Teamwork is critical, uncooperative / leeching members will be penalized heavily

	Out of
Time Keeping	5
Content Quality	
- Depth of research	3
- Able to explain content well	3
- Defines context and states assumptions clearly	3
- Logical flow of Presentation	3
- Use of relevant examples	3
Q&A	
- Able to defend assessment / analysis	2
- Demonstrates strong understanding of topic	3
Total Score	25

Defining the Threat Type

Cyber Espionage

Cyber espionage is primarily used as a **means to gather sensitive or classified data, trade secrets or other forms of IP** that can be used by the aggressor to create a competitive advantage or sold for financial gain.

In some cases, the breach is simply intended to cause reputational harm to the victim by exposing private information or questionable business practices.

Financial Crime

Financially motivated cybercriminals are individuals or groups who engage in illegal activities online **with the primary goal of making money**. Their actions typically revolve around exploiting vulnerabilities in computer systems or networks to steal sensitive data, extort money, or disrupt operations for financial gain.

These criminals are driven by profit, not ideology or activism.

Hacktivism

A cyber hacktivist is an individual or group who utilizes hacking techniques to **promote a political or social agenda**. Unlike financially motivated cybercriminals, hacktivists are driven by ideology and a desire to effect change, rather than personal profit.

They often target organizations or governments they perceive as corrupt, unjust, or oppressive.

Information Operations

Information operations (IO) are coordinated actions taken to **influence, disrupt, or exploit an adversary's decision-making process** while safeguarding one's own information and information systems.

Group Presentation Topics

1. Define and explain cyber threats to 5G networks, what are the implications and how can it affect consumers' lives?
2. Define and share more about state sponsored cyber espionage. Explore case studies related to state sponsored cyber attacks
3. Define and explain cyber threats to mobile applications and devices, explore the severity and what are the motivations for actors leveraging this attack vector. What are the general trends?
4. Define and explain misinformation / information operations campaigns, what is the motive and why is it important ?
5. Define and explain threats to cloud platforms / infrastructure?
6. Define and explain the Financial criminal trends in Southeast Asia. Consider Dark web / social media / telegram groups etc.
7. Define and explain types of threats to social media end users (FB/IG/TikTok etc.) why is it important and how can it affect consumers lives?
8. Explore the different types of financial scams that are happening in Singapore in 2025, explore the different kinds of lure themes and explore how we can solve the scam problem
9. Explore cyber threats emerging from AI and towards AI models, how are threat actors using it for attacks? Any trends?
10. Explain cyber threats to cryptocurrency, explore threats to the integrity of blockchain / crypto technology or crypto-platforms

Analyst Tradecraft

- **Intelligence as a discipline has existed for a long time**
 - Analytical process, inductive / deductive reasoning, source evaluation, confidence levels...
- **Technology also has its own disciplines**
 - Hardware and software engineering, systems integration, networks and protocols, exploits and vulnerabilities...
- **Only recently have we tried to apply the intelligence process to data from computer operations and intrusions**
 - Many intelligence analysts don't sufficiently understand technology
 - Many security researchers don't sufficiently understand the intelligence process

This is why attribution is hard...and why it's so prone to error

What are the downsides of wrong attribution?

Cyber Attacks: The Challenge of Attribution and Response



- When attempting to work out who may be behind an attack, incident responders typically assess both indicators of compromise (IoCs) and attackers tactics, techniques, and procedures (TTPs) that had been observed during the respective attack.
- While IoCs are often a good place to start, attacker **infrastructure like IP addresses, domains, can easily be spoofed or generated in a manner which will obfuscate the attackers real identity.**
- In the solarwinds cyber attack, Russian attackers have even been observed hijacking infrastructure used by Iranian state sponsored groups. **This was likely to piggyback from their cyber espionage campaign and to attack government and industry organizations,** all while masquerading as attackers from the Islamic Republic.
 - This highlights the complexity in providing a confident attribution to individual attacks, given attackers clearly place precedence on covering their tracks .

2 Types of Thinking

According to Dual Process Theory, we have two forms of thinking:

- **System 1**

- Intuition
- Fast
- Intuitive
- Draws on past experience
- Permits quick judgement
- Often accurate

How we perceive the world around us, recognise objects, orient attention, avoid losses - and fear spiders!

- **System 2**

- Analytic
- Slow, deliberate, considered
- High effort
- Rule based
- Abstract

Activated when we do something that does not come naturally and requires some sort of conscious mental exertion.

Cognitive Bias



2 Types of Thinking

A common example used to demonstrate the two systems is the following puzzle:

A bat and a ball together cost \$1.10. The bat costs \$1 more than the ball. How much does the ball cost?

Faced with this puzzle, the majority of people instantly guess 10 cents.

The correct answer, however, is 5 cents - which, again, most people can work out after spending more time thinking about the question.

For years, this has been used as a perfect example of how the way we think is ruled by two types of mental processes: fast and intuitive, versus slow and analytical.

Cognitive Bias

- Mental Errors
- Like optical illusions, the evidence appears compelling even when one is fully aware of its nature
- 5 most common analytical traps:
 - Failing to consider multiple hypotheses or explanations
 - Ignoring inconsistencies
 - Reject evidence that does not support the hypothesis
 - Insufficient resource to capture key evidence
 - Improperly projecting past experience

Applying Cognitive Biases to Cyber Intelligence

Failure to consider Visibility

- A form of “**failing to consider multiple hypotheses or explanations**”
- Different organizations have different views of the threat landscape
- Your environment, your country, your industry (locally or globally...)
- Your view may affect your interpretation of events
 - Example: suspicious email with unknown backdoor sent to CFO...this must be targeted!
 - Example: this activity is hitting customers of European-based banks...this must be regionally-focused cyber crime!

Mixing Fact with Assessments

Can result in a failure to “cope with evidence of uncertain accuracy”

- Threat intelligence deals with what we know (data, facts) and what we think (**assessment, opinion, confidence**)
 - Many analysts don't clearly differentiate between the two in their analysis
 - Many security organizations don't clearly differentiate in their public research
 - Many media organizations don't clearly differentiate in their reporting
- Example:
 - “Team Wombat domain “news.myworldnews.com” resolved to IP 12.34.56.78. Domain mail.mediacorp.com also resolved to the same IP.” (fact)
 - Possible misinterpretation: “Domain mail.mediacorp.com is attributable to Team Wombat.” (assessment)
 - **WHY?**

Failing to Properly Vet Sources

Just like any IT function, threat intelligence lives and dies on the quality of inputs — garbage in, garbage out.

Despite this, many organizations start their threat intelligence program by signing up for a series of open source threat feeds without having a proper vetting process in place.

This can result in a flood of alerts that are difficult to differentiate or trust.

- Because so many alerts arrive without context and turn out to be false positives or redundancies, it's no surprise that around 44% go completely uninvestigated. And of the remaining 56%, only around half get resolved.

Failure to Account for Human Action

In the landscape of computer operations, we deal with data

- It's easy to forget that there is a person behind the keyboard

Our minds naturally want to sort and categorize information

- We want to make sense of our environment; not always comfortable with grey areas

“The simplest solution is the most likely solution”

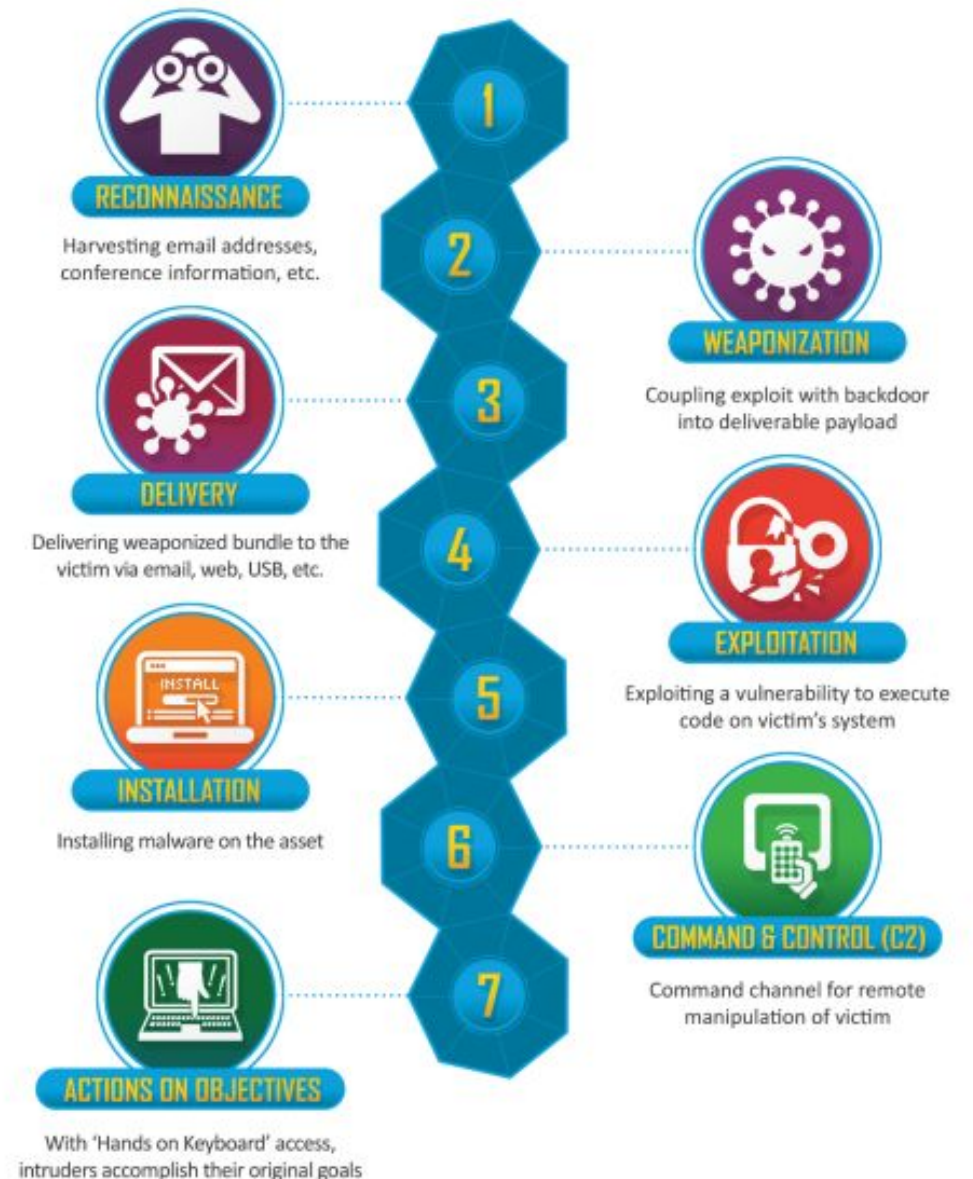
- Except when it comes to people

“Threat groups” may be neither monolithic nor self-contained

Cyber Kill Chain

The cyber kill chain is an adaptation of the military's kill chain, which is a step-by-step approach that identifies and stops enemy activity.

Originally developed by Lockheed Martin in 2011, the cyber kill chain outlines the various stages of several common cyberattacks and, by extension, the points at which the information security team can prevent, detect or intercept attackers.



Stage 1 – Reconnaissance

- In this step attackers try to collect as much information as possible about their targets to devise a robust attack.
- During reconnaissance, attackers may harvest a range of information from target mailing lists, presence in social media, open ports to potential vulnerabilities in target services and applications.
- Collected information are usually used to decide about best tool of attack (i.e., a targeted exploit, an exploit kit or a worm) to successfully penetrate into target environment and achieve attack objectives

Stage 2 – Weaponization

- During weaponization, attackers armor their malicious payload with means of by-passing security controls in the target environment (i.e., for a smooth execution)
- They use a range of techniques from disguising a malware in a benign looking payload, such as Adobe Portable Document Format (PDF) or Microsoft Office documents, to exploiting a remote-access O-day vulnerability to disable target machine security protections

Stage 3 – Delivery

- Vulnerability scanning + phishing emails
- Regardless of how sophisticated and robust is a weaponized malicious payload, an attacker should find a way to get it delivered to the intended target(s).
- In the delivery step, attackers are formulating possible means, e.g., through malicious email attachments or USB flash drive

Stage 4 – Exploitation

- Exploitation is when the rubber meets the road.
- This is when the armoured payload exploits a vulnerability on the target environment and executes its malicious binary payload and provides the attacker with minimum required access to the target environment.
- Introduction of Crimeware-as-a-Service (CaaS) further reduced attackers hassle at this stage.

Stage 5 – Installation

- In this step, attackers try to further their access to more nodes (i.e., propagating the malware in the network) and install remote administration tools, i.e., Remote Access Trojans (RAT) or Backdoors to persist their presence on the target environment

Stage 6 – Command and Control (C2)

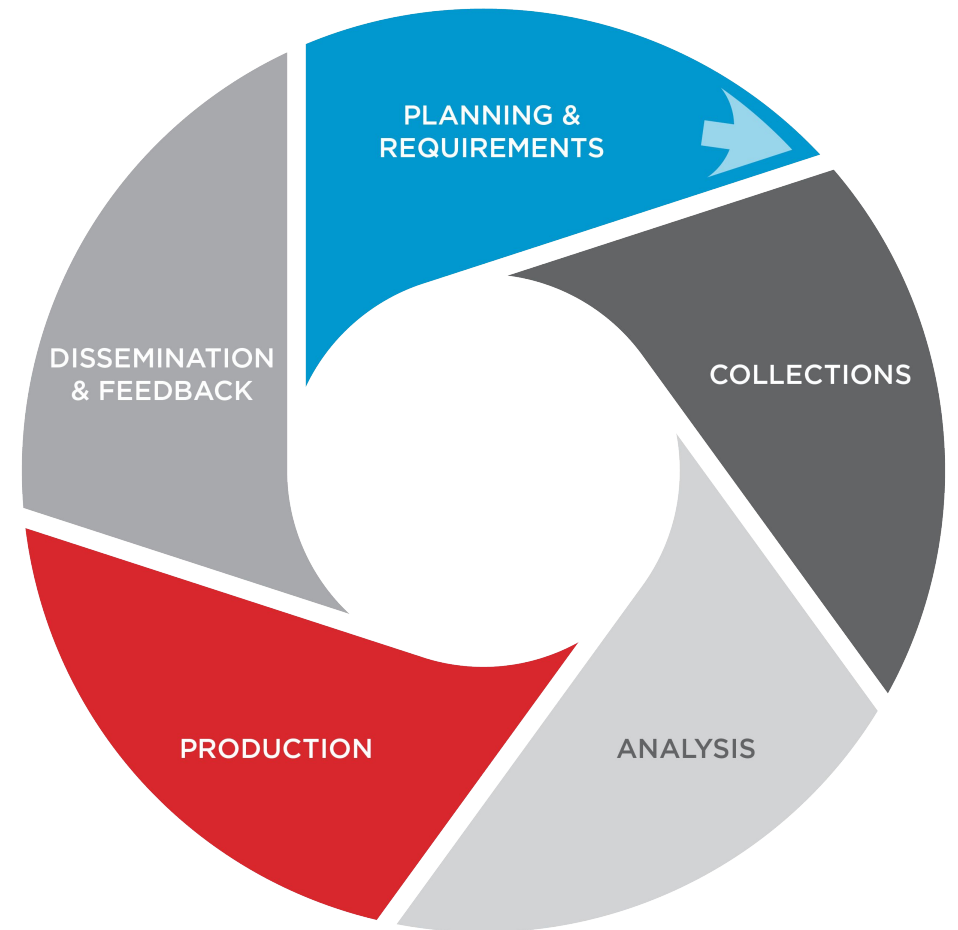
- After being installed on the victim machine(s), it is time for attackers to have their (virtual) hands on the target keyboards through setting up a remote Command and Control (C&C, also known as C2).
- The C2 channels can be used to deliver attackers commands to the malware or exfiltrate data from the target environment

Stage 7 – Actions on Objectives

- Finally, after successful installation, and C&C establishment, it is time to perform desired action(s) to meet the attack objectives.
- Attackers could have different objectives from just accessing and exfiltrating private information to encrypting files and denying custodians access to their data

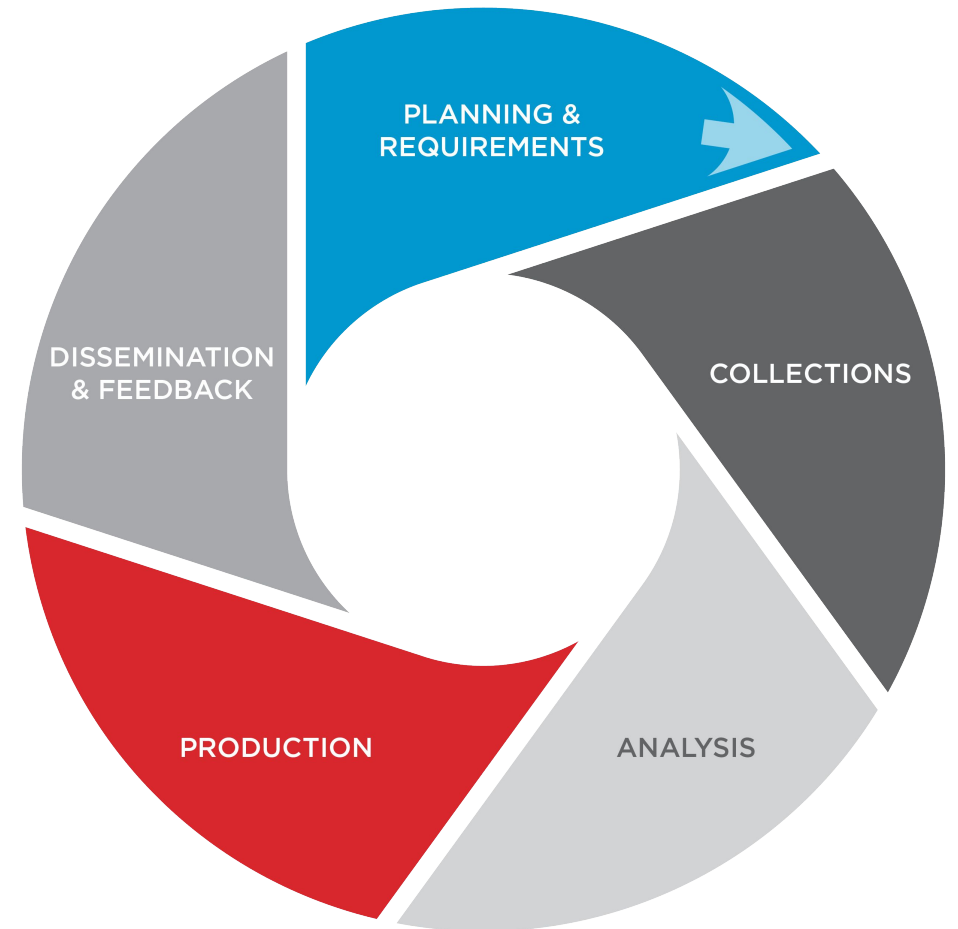
The Intelligence Cycle – industry best practice

- Planning and Requirements
 - Stakeholders defined
 - Business needs and information concerns
- Collections (Information sources)
 - Raw Internal and external data
 - Open source, commercial, and sensitive
- Analysis
 - Collation and aggregation (Threat Intel Platform (TIP))
 - Analyst best practices (analytical methodology)



The Intelligence Cycle – industry best practice

- Production
 - Estimative language
 - Challenge analysis
- Dissemination and Feedback
 - Role-based intelligence reporting
 - Feedback loop firmly established



The Intelligence Cycle – Case Study

You are a CTI analyst at Maplewood University, a large American institution of higher education.

Located on the East Coast of the United States, Maplewood University boasts an impressive enrollment of over 40,000 students from around the world and employs more than 10,000 staff, researchers, and student workers.

- As a nationally recognized research institution, the University invests significantly in research initiatives and the development of sophisticated laboratories across diverse fields of study.
- **This morning, a tech news outlet reported that a nearby university, Pine Grove, was recently the target of a campus-wide spear-phishing campaign.**



TECH NEWS



BREAKING NEWS

Pine Grove University Reeled Into New Phishing Scam



KEEP READING >

The Intelligence Cycle – Case Study

- According to the article, thousands of staff and student workers received emails claiming to be from the University “Payroll Department”. **These messages urgently directed workers to log into their university-issued accounts and immediately update their “outdated” banking information or risk not receiving their due pay.**
- Pine Grove University promptly responded to the article, stating in a press release that hundreds of university accounts had been compromised as a result of the attack and that the incident was under investigation.
- These accounts contained a wealth of personally identifiable information (PII), including such critical information as individuals’ social security numbers and bank account details.



TECH NEWS



BREAKING NEWS

Pine Grove University Reeled Into New Phishing Scam



KEEP READING

The Intelligence Cycle – Case Study

- Alarmed by the attack on Pine Grove, the President of Maplewood University approaches your team, concerned that your institution may be in imminent danger.
- She wants **you to determine the likelihood that Maplewood will also be targeted by this spear-phishing campaign and identify measures the University** can implement to defend against any future phishing attacks.



TECH NEWS



BREAKING NEWS

Pine Grove University Reeled Into New Phishing Scam



KEEP READING >

The Intelligence Cycle – Case Study

- In response to the Pine Grove University attack, a key stakeholder at Maplewood University—the President—establishes two new requirements, and, in doing so, propels the CTI life cycle into motion. She directs you to:
- “determine the likelihood that Maplewood will also be targeted by this spear-phishing campaign,”
- “identify measures the University can implement to defend against any future phishing attacks”



TECH NEWS



BREAKING NEWS

Pine Grove University Reeled Into New Phishing Scam



KEEP READING

Planning and Requirements



For each intelligence requirement, there are also corresponding collection requirements.

These are the data and observables that must be collected in order to answer your intelligence requirements.

High-level requirements relate to the overarching interests and strategic objectives of an organization:

Geography: where the organization is physically situated (e.g. California; South America)

Industry: the industries or verticals in which the organization operates (e.g. Healthcare; Fintech)

Critical Assets: the organizational assets that are most valued or targeted by adversaries (e.g. PII; Intellectual Property)

Historical Incidents: the types of incidents previously experienced by an organization (e.g. account credential theft; corporate espionage)

Adversary: the attackers most likely to target the organization (e.g. hacktivist; nation-state)

Functional requirements are similar to high-level requirements, but they **focus instead on the operational and technical interests of the organization**, like what software is used and which devices have access to the internal network.

This offers **greater insight into which cyber threats pose the greatest risk to an organization from a practical perspective** and helps analysts further refine their requirements according to the organization's technical landscape.

This means if Maplewood University uses exclusively Microsoft systems running Windows 11, they probably do not need to be concerned about malware designed to compromise Apple devices.

Planning and Requirements



Maplewood University High Level Requirements	
Industry	Research and Education
Business Plan	Maplewood University is a private, for-profit institution of higher education. It serves over 40,000 students annually and employs more than 10,000 staff, researchers, and student workers. The University profits primarily from student admissions expenses. As a nationally recognized research institution, the University also frequently receives significant donations from alumni and other benefactors to support emerging scholarship and the continued improvement of campus facilities.
Critical Assets	Intellectual Property (IP); Personally Identifiable Information (PII)
Geography	East Coast, United States; North America
Historical Incidents	Data exfiltration; account credential theft via phishing; website defacement
Adversary	Insider threats; cybercriminals; hacktivists
Intelligence Consumer	President of Maplewood University

Planning and Requirements



Maplewood University Functional Requirements

Software	• Windows 11 • macOS 14 Sonoma • Microsoft Office 365 • Adobe Creative Cloud • ChemOffice
Computing Accounts Issued	• Active Directory Service (ADS) domain account • Microsoft Exchange email account
Authentication	Single sign-on (SSO) with ADS account
Learning Management System	Canvas

Planning and Requirements



Production Requirement	Intelligence Requirement
What is the likelihood that Maplewood University will also be targeted by this spear-phishing campaign?	• What are the intentions of the adversary who attacked Pine Grove University? • Have there been any other spear-phishing attacks against similar American institutions of higher education within the last 180 days that significantly overlap with the Pine Grove attack? • What tactics, techniques, and procedures (TTPs) did the adversary employ to successfully attack Pine Grove University? • What indicators exist that the adversary plans to attack Maplewood University as well? • What made previous spear-phishing attacks against Maplewood University successful?
What measures could the University implement to defend against any future phishing attacks?	• What defenses have similar large American institutions of higher education successfully implemented to defend against spear-phishing campaigns? • What types of employee and end user training are most successful at preventing spear-phishing attacks at American institutions of higher education? • What types of spear-phishing campaigns have been employed against American institutions of higher education within the last 180 days?

Planning and Requirements



Production Requirement	Intelligence Requirement	Collection Requirement
PR #1	What are the intentions of the adversary who attacked Pine Grove University?	- Consult HEN-ISAC Threat Intelligence System (TIS) - Liaise with Pine Grove CTI and Incident Response (IR) teams
	Have there been any other spear-phishing attacks against similar American institutions of higher education within the last 180 days that significantly overlap with the Pine Grove attack?	- Review threat feeds - Review HEN-ISAC Threat Intelligence System (TIS) for similar attacks - Monitor dark web forums - Gather OSINT from X, other social media platforms
	What tactics, techniques, and procedures (TTPs) did the adversary employ to successfully attack Pine Grove University?	- Consult HEN-ISAC Threat Intelligence System (TIS) - Liaise with Pine Grove CTI and Incident Response (IR) teams
	What indicators exist that the adversary plans to attack Maplewood University as well?	- Gather OSINT - Monitor dark web forums
	What made previous spear-phishing attacks against Maplewood University successful?	Consult Maplewood Security Operations Center (SOC) and Incident Response (IR) teams
PR #2	What defenses have similar large American institutions of higher education successfully implemented to defend against spear-phishing campaigns?	- Liaise with nearby HEN-ISAC members - Review reporting from similar University incidents - Review annual Proofpoint "State of the Phish" report and other research
	What types of employee and end user training are most successful at preventing spear-phishing attacks at American institutions of higher education?	- Liaise with nearby HEN-ISAC members - Review reporting from similar University incidents - Review annual Proofpoint "State of the Phish" report and other research
	What types of spear-phishing campaigns have been employed against American institutions of higher education within the last 180 days?	- Review threat feeds - Review HEN-ISAC Threat Intelligence System (TIS) for other attacks - Monitor dark web forums - Gather OSINT from X, other social media platforms

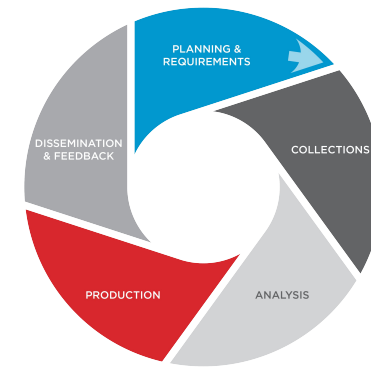
Collections

Data Source	Examples	Types of Data Gathered
Open-Source Intelligence (OSINT)	- social media platforms - public websites	- information about threat actors, organizations, and campaigns - domain names, usernames, email addresses
Technical Data	- network traffic logs - firewall logs	- IP addresses and domains involved in network traffic - source and destination addresses in firewall logs
Incident Reports	- internal reports - external reports	- details of historical incidents - remediation steps taken
Dark Web	- dark web marketplaces - dark web forums	- data and credentials for sale - discussions of planned attacks - hacking tools and services for sale
Threat Feeds	- commercial feeds - open-source feeds	- known malicious domains and IP addresses - information about emerging threats
Human Intelligence (HUMINT)	- colleagues - professional contacts	- insights from security professionals - threat intelligence shared through communities



Collections

Production Requirement	Intelligence Requirement	Collection Requirement
PR #1	What are the intentions of the adversary who attacked Pine Grove University?	- Consult HEN-ISAC Threat Intelligence System (TIS) - Liaise with Pine Grove CTI and Incident Response (IR) teams
	Have there been any other spear-phishing attacks against similar American institutions of higher education within the last 180 days that significantly overlap with the Pine Grove attack?	- Review threat feeds - Review HEN-ISAC Threat Intelligence System (TIS) for similar attacks - Monitor dark web forums - Gather OSINT from X, other social media platforms
	What tactics, techniques, and procedures (TTPs) did the adversary employ to successfully attack Pine Grove University?	- Consult HEN-ISAC Threat Intelligence System (TIS) - Liaise with Pine Grove CTI and Incident Response (IR) teams
	What indicators exist that the adversary plans to attack Maplewood University as well?	- Gather OSINT - Monitor dark web forums
	What made previous spear-phishing attacks against Maplewood University successful?	Consult Maplewood Security Operations Center (SOC) and Incident Response (IR) teams
PR #2	What defenses have similar large American institutions of higher education successfully implemented to defend against spear-phishing campaigns?	- Liaise with nearby HEN-ISAC members - Review reporting from similar University incidents - Review annual Proofpoint "State of the Phish" report and other research
	What types of employee and end user training are most successful at preventing spear-phishing attacks at American institutions of higher education?	- Liaise with nearby HEN-ISAC members - Review reporting from similar University incidents - Review annual Proofpoint "State of the Phish" report and other research
	What types of spear-phishing campaigns have been employed against American institutions of higher education within the last 180 days?	- Review threat feeds - Review HEN-ISAC Threat Intelligence System (TIS) for other attacks - Monitor dark web forums - Gather OSINT from X, other social media platforms



Analysis



Information Review

Reviewing the collected information after processing steps like normalization and validation



Enrichment

Adding context to the processed information to enhance its value



Pivoting

Exploring connections between different indicators to uncover patterns and trends in the information



Contextualization

Considering the implications and relevance of the information in the context of the organization



Correlation

Correlating information from multiple sources to validate findings



Analysis

Applying analysis techniques to hypotheses to limit cognitive biases and compiling findings



Analysis

Navigate to the spoofed domain–pinegrove[.]online–in a sandbox environment. This allows you to interact freely with the malicious website while mitigating the risk of compromise to your host system.



PINE GROVE UNIVERSITY
STUDENT PORTAL

Email Address

Password

[Need help?](#) [Forgot your password?](#) [Sign In](#)

Spoofed Page

Submitting a fake username and password here redirects you to “pinegrove[.]online/directdeposit” and a virtual form titled “Employee Direct Deposit Form”.

This form instructs victims to enter their banking details along with a wealth of personally identifiable information (PII), including their Social Security Number (SSN) and University ID.

PINE GROVE UNIVERSITY

Employee Direct Deposit Form

FAILURE TO COMPLETE THIS FORM WILL RESULT IN THE AUTOMATIC TERMINATION OF YOUR DIRECT DEPOSIT SERVICE.

Name *
 First Middle Last

Employee ID * **University Email Address ***

Phone Number * **Social Security # *** **Date of Birth ***

Bank Name * **Bank Routing Number ***

Bank Account Number * **Bank Account Type ***

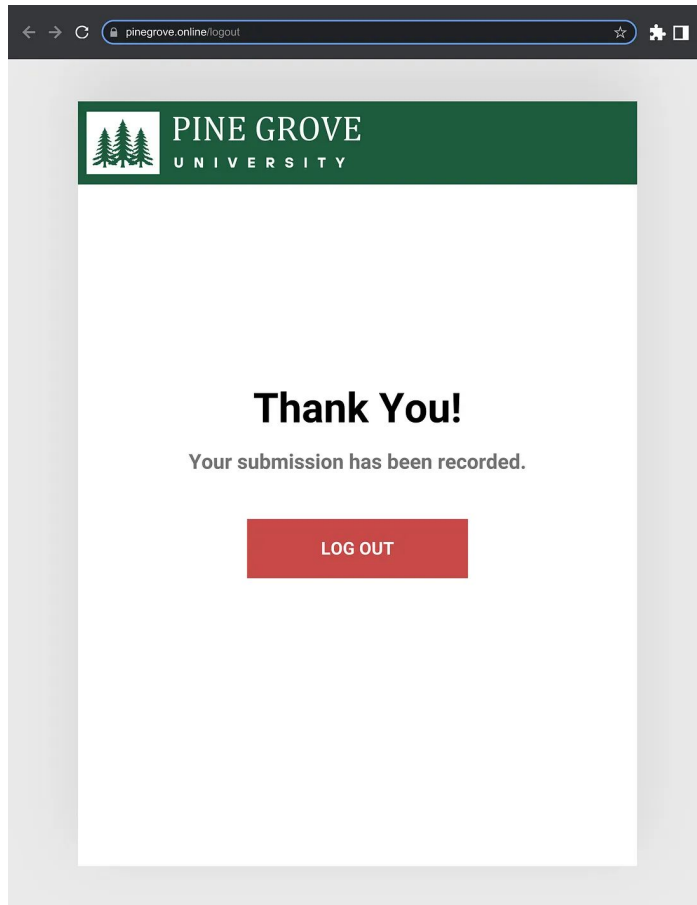
Home Address *
 Street Address
 City State Zip Code

☐ I certify that the information provided is correct. *

[Submit](#)

Analysis

Entering fake data once again leads to a submission confirmation page where victims have the option to “log out”, which returns them to the original spoofed Pine Grove University login page.



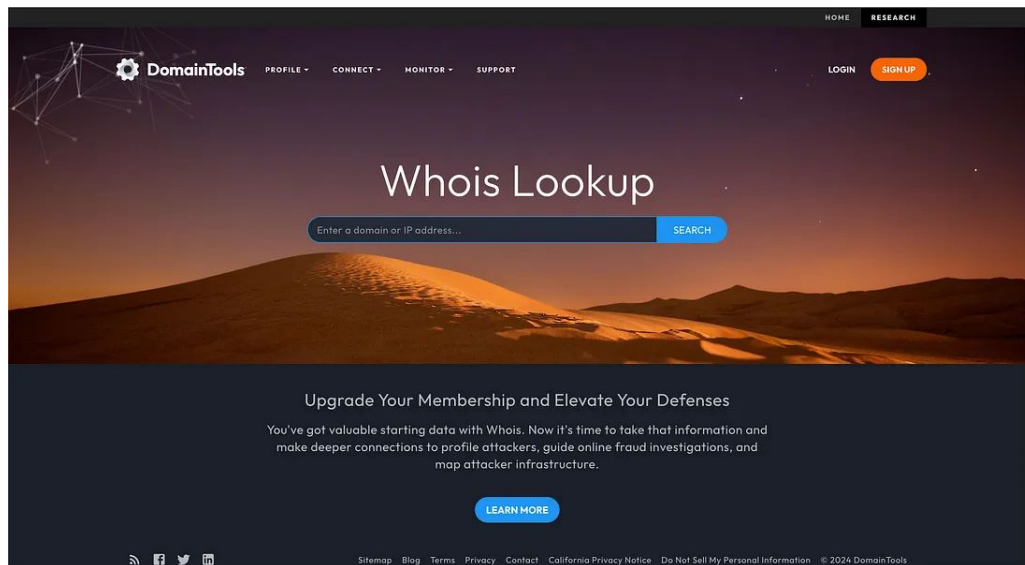
The inclusion of a spoofed login page in addition to the fake direct deposit form reveals this to be a two-part attack aimed at acquiring both the victim's account credentials and their banking details; in other words, enough information to both impersonate and defraud them with little difficulty.

Analysis

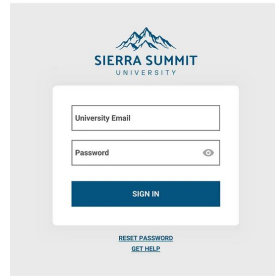
To further contextualize the phishing domain, you use the free open-source intelligence tool Whois Lookup by DomainTools, which compiles basic domain registration and infrastructure information.



- According to the Whois record for pinegrove[.]online, the spoofed site was created just 30 days ago using a domain registrar and hosting provider commonly chosen by malicious actors for establishing phishing sites.
- Unsurprisingly, the registrant opted to redact all personal identifying information, so it remains unclear who created the domain; however, this record still reveals some interesting information, including the adversary's infrastructure preferences and the IP address of the host server.
- The Whois record indicates that this host server IP address is associated with only four other domains, which suggests a potential overlap between them.



Analysis



To pivot off the host server IP address, you perform a reverse IP lookup, which yields the following four domains:

- sierrasummit[.]online
- crescentvalley[.]online
- aspenstate[.]online
- libertyhills[.]online

Each of these domains appears to be impersonating a legitimate university login page, just like the domain employed for the Pine Grove phishing attack.

You pivot once again by performing additional Whois lookups on the four related domains. The Whois records for these domains reveal that each is less than 30 days old and leverages the same basic infrastructure as the impersonated Pine Grove site. This indicates significant overlap between all five domains.

To confirm that the four related domains host the same phishing scam, you visit each in a sandbox environment. As expected, all four domains present the same sequence of phishing pages as the spoofed Pine Grove site with only minor aesthetic modifications to better impersonate each institution.

Unsurprisingly, each spoofed login site is nearly indistinguishable from the original.

Analysis



After briefly reviewing the official websites for each institution, a pattern in the victim profile also emerges: **each of the five targeted universities is a large R1 research institution located on the East Coast of the United States.** This suggests another potential adversary objective: **the exfiltration of intellectual property data, namely classified research.**

Aware that **Maplewood University fits your current victim profile and that these five institutions may not be the only targets of the spear-phishing campaign, you search for spoofed versions of the Maplewood University login page that match the naming conventions of the other phishing domains, but none currently exist.** However, this does not eliminate the possibility that Maplewood will be victimized by this spear-phishing campaign, as well.

Production

We chose this method to disseminate the intelligence to the President because it is a familiar channel of communication; executives are accustomed to receiving information in the form of written reports and formal briefings.

By adhering to these professional standards, you increase the likelihood that the intelligence deliverables will be actionable for the President.

EXECUTIVE REPORT

Payroll Phishing Campaign Targets American Institutions of Higher Education

EXECUTIVE SUMMARY

We estimate that it is likely Maplewood University will be targeted by the same spear-phishing campaign as Pine Grove University for two reasons: 1) Maplewood University significantly overlaps with the profiles of other known and suspected targets; and 2) Maplewood University has previously demonstrated a vulnerability to phishing attacks that leverage brand impersonation. To limit the success of this spear-phishing campaign and other phishing scams, we recommend the implementation of a multi-layered defensive approach that balances technical controls with regular end-user training initiatives.

KEY POINTS

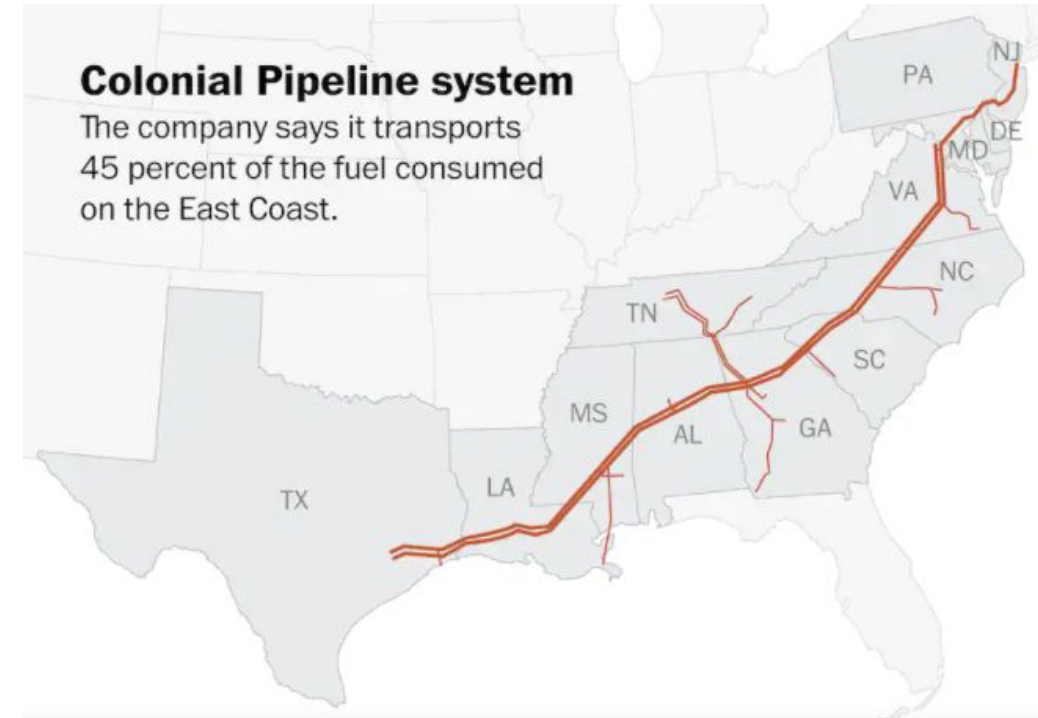
- Pine Grove University recently experienced a spear-phishing attack in which the adversary impersonated the University Payroll Department in order to steal victims' university account credentials and banking details. Victims were directed to click a malicious link in the phishing email to update their banking information or risk the termination of their direct deposit services.
- Analysis of this link revealed four related domains impersonating other universities. Each of these sites hosted the same phishing pages as the Pine Grove attack but were rebranded to look like the other targeted institutions.
- The five target universities are all R1 research institutions located on the East Coast of the United States. Additionally, they all lack multi-factor authentication.
- Maplewood University also fits this victim profile, but there are no indicators that Maplewood is currently a target.
- According to Proofpoint's annual "State of the Phish" report, current best practices for defending against phishing balance technical controls with end-user training and organizational culture shifts in support of cybersecurity.
- Based on this research, we recommend the following defenses be implemented:

TTP Review - Class Walkthrough

- The Threat Actor: DarkSide (a Cybercriminal Syndicate)
- The Mission: To extort a multi-million dollar ransom by paralyzing critical energy infrastructure.

1) The breach was initiated when attackers gained entry to the company's internal network using a single compromised password for a legacy Virtual Private Network (VPN) account.

2) This account was no longer in active use by the company but had not been deactivated, and critically, it did not require Multi-Factor Authentication (MFA) to log in.



TTP Review - Class Walkthrough

3) Once the attackers established this initial "foothold," they began exploring the network to identify high-value targets. They utilized a common penetration testing tool called Mimikatz to harvest additional credentials from the memory of the first compromised machine. By obtaining these legitimate usernames and passwords, they were able to move laterally across the corporate network, jumping from the VPN gateway to the internal accounting and billing servers.

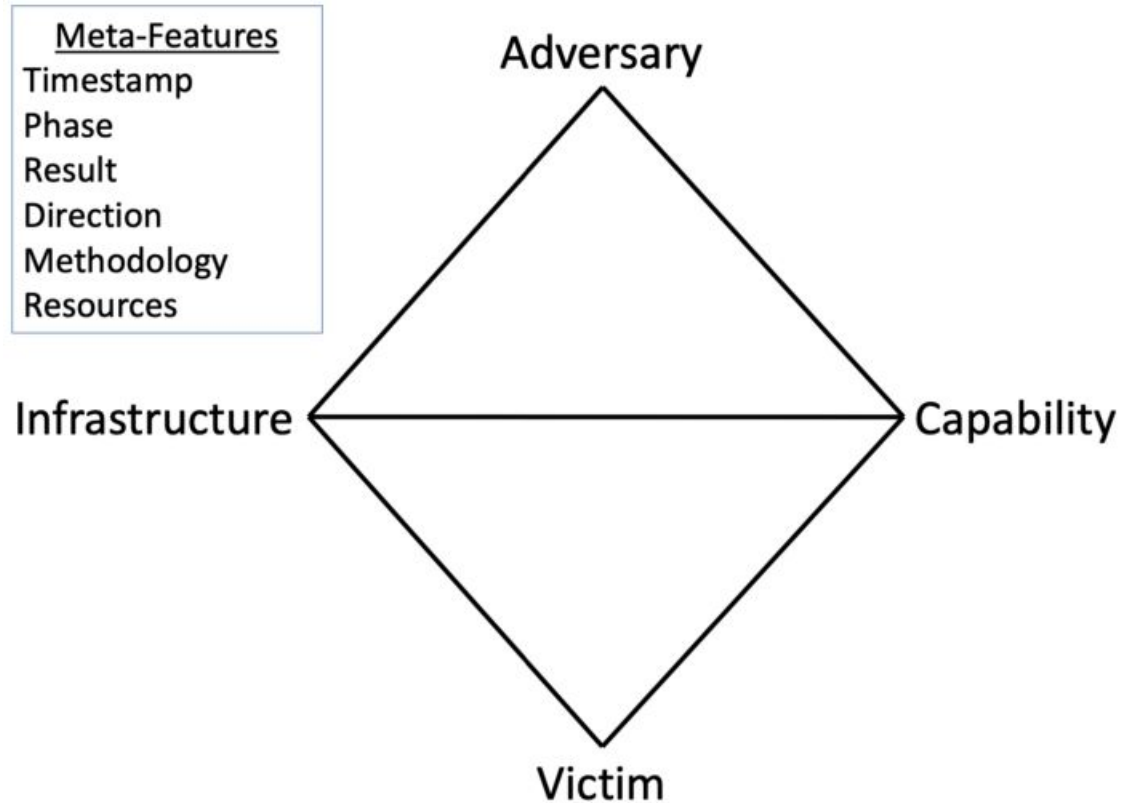
4) Before triggering any visible disruption, the attackers spent several hours quietly identifying and collecting sensitive corporate data. They successfully moved approximately 100 gigabytes of data out of the network to their own external servers. This was done to ensure they had "leverage" for a double-extortion scheme—threatening to leak the data publicly even if the company managed to restore its systems from backups.

5) Finally, the attackers deployed their primary payload: the DarkSide ransomware. This software automatically scanned the compromised servers and applied high-grade encryption to all business-critical files, including the systems used for customer billing and fuel dispatching. Within minutes, employees discovered digital ransom notes on their screens, demanding 75 Bitcoin (approximately \$4.4 million at the time) in exchange for the decryption key.

TTP Review - Class Walkthrough

Tactic (The Goal)	Technique (The Method)	Procedure (The Specific Action)
Initial Access		
Lateral Movement		
Exfiltration		
Impact / Extortion		

Diamond Model



Consider

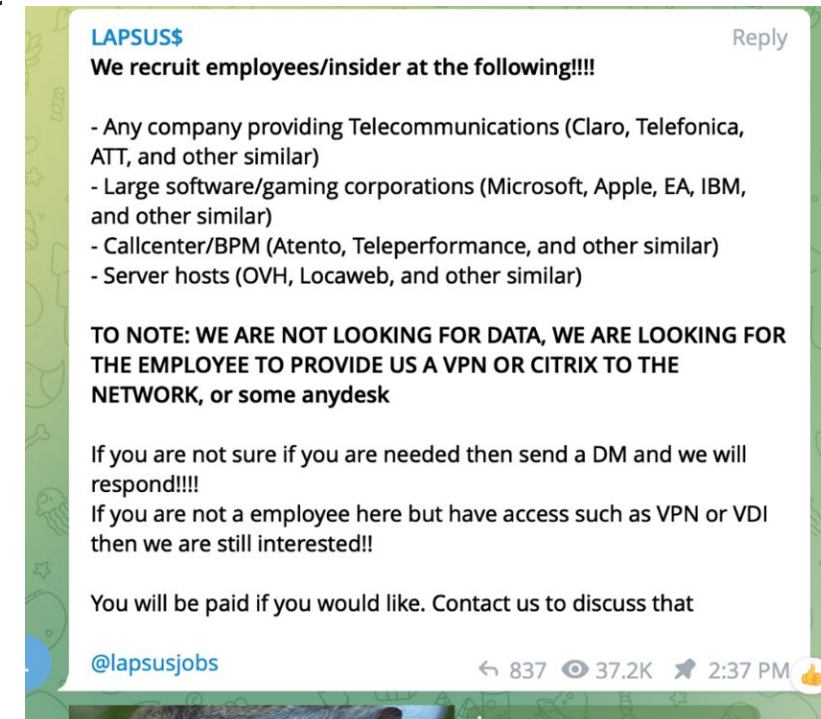
- Timestamp: date and time intrusion event occurred
- Result: outcome of intrusion (e.g., success, failure, or unknown; or confidentiality compromised, integrity compromised, and/or availability compromised)
- Direction: how event moved through network or host (e.g., Victim-to-Infrastructure, Adversary-to-Infrastructure, Bidirectional)
- Methodology: category of event (e.g., spearphishing, port scan)
- Resources: elements required for intrusion (e.g., particular software, hardware, knowledge, funds, facilities, access)
- Social-political: relationship between adversary and victim, based on victim's needs and aspirations
- Technology: tech involved in adversary's capabilities and use of infrastructure

Diamond Model – Apply to The Lapsus Group



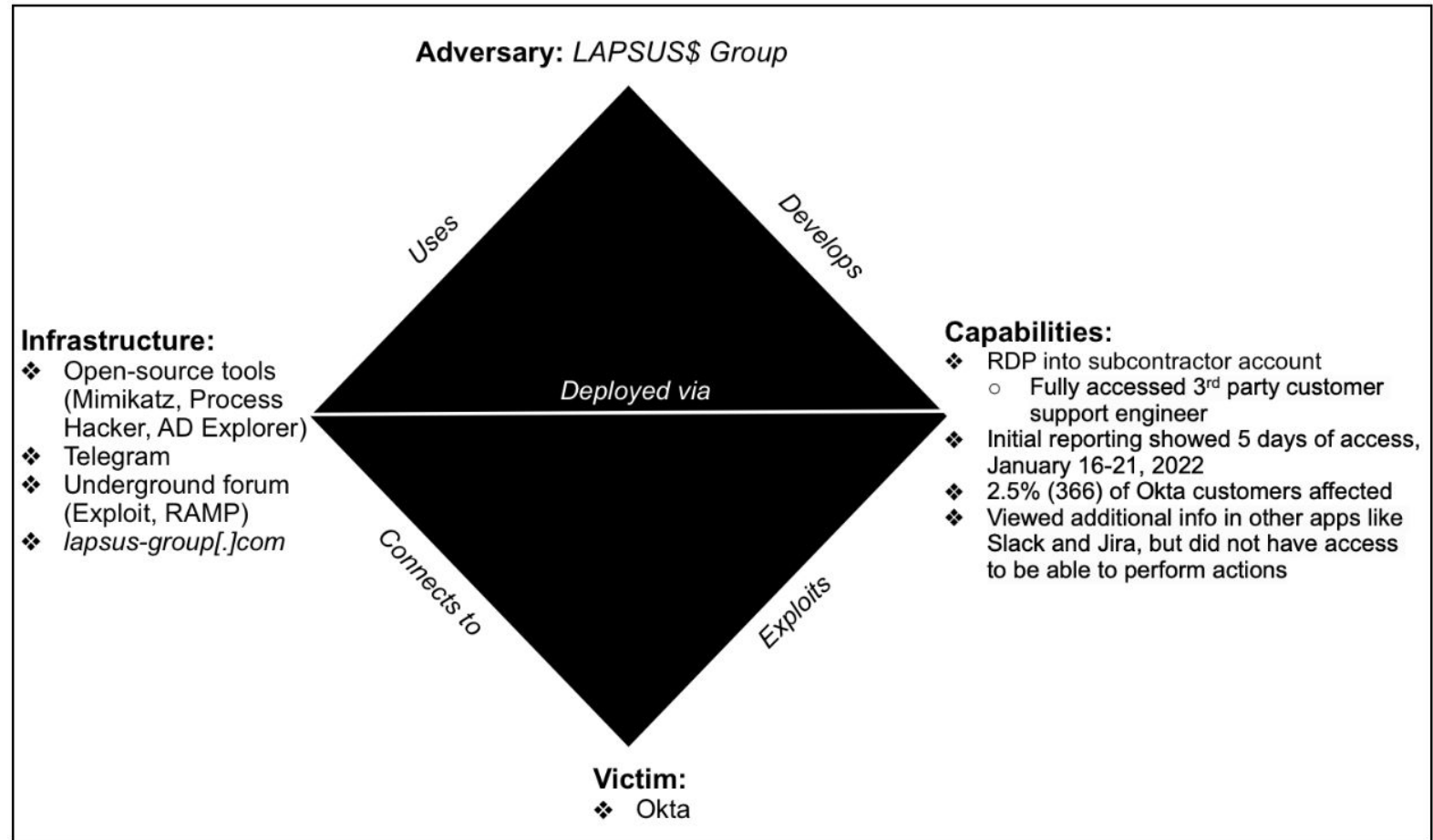
Background of LAPSUS\$

- LAPSUS\$ Group first became subject to widespread media attention in December 2021, when they launched a ransomware attack against the Brazilian Ministry of Health (Ministério da Saúde).
- The attackers compromised several of the health ministry's systems, exfiltrating internal vaccination data and ordering officials to contact LAPSUS\$ in order to retrieve the stolen information.
- It quickly became apparent that members of LAPSUS\$ were just getting started. Following the attack in Brazil, the group executed additional cyberattacks against at least 8 major technology companies.
- With each campaign, the group's members utilized Telegram to dump stolen data and recruit additional members. In just a few short months, LAPSUS\$ had acquired 50,000 subscribers on their Telegram channel and leaked at least hundreds of gigabytes of sensitive information.



OKTA Case Study

- In January 2022, the public security company Okta suffered a cyberattack by LAPSUS\$.
- This incident shook the cybersecurity world, especially given the fact that Okta provides identity management and authentication services to over 15,000 organizations. LAPSUS\$ claimed they targeted Okta in order to get access to the company's customer accounts.



Thank You